would be required to provide notice to each individual whose sensitive customer information resides in the customer information system.[87] In addition, providing notice of every incident, regardless of the risk of harm to affected individuals or the need to take protective measures, could diminish the impact and effectiveness of the notice in a situation where enhanced vigilance is necessary. Utilizing a "reasonably possible" standard raises similar concerns, as it could require covered institutions to provide notice in situations where it is possible, but not reasonably likely, that sensitive customer information was compromised. This could result in over-notification where, for example, a customer's sensitive information ultimately was not accessed or used without authorization, but it was not possible to rule out that possibility at the time of the incident or in the course of a reasonable investigation during the 30-day period for notices.

Additionally, we are not adopting a commenter's recommendation that the Commission require covered institutions to provide notices to the Commission when they are required to send notices to affected individuals, as one commenter suggested.[88] A primary reason for these amendments was to require a reasonably designed incident response program, including policies and procedures for assessment, control and containment, and customer notification, in order to mitigate the potential harm to individuals whose sensitive information is exposed or compromised in a data breach.[89] Providing timely notices to affected individuals accomplishes this goal without the need for covered institutions also to provide copies of the notice to the Commission.

Conversely, the narrower alternative standards suggested by commenters (i.e., that covered institutions have a notification obligation only after an investigation, and only if they

---

87 *See* final rule 248.30(a)(4)(i) and (ii).

88 *See* Better Markets Comment Letter.

89 Proposing Release at section I.

affirmatively determine a likelihood of a breach or resulting harm to customers) could result in an unreasonable risk of significant delays in providing notice and in notification not being provided to affected individuals. A principal purpose of these amendments is to provide a notification regime that allows affected individuals to take actions to avoid or mitigate the risk of substantial harm or inconvenience.[90] If customer notification of a potential breach was delayed to allow a covered institution to complete an investigation that comes to a definitive conclusion about the precise details of the breach, even if done promptly, it would frustrate this goal by postponing (or potentially limiting or foreclosing) the ability of affected individuals to take mitigating actions pending the conclusion of that investigation. For these same reasons, we were not persuaded by those commenters who suggested that we should allow for the completion of an investigation in order to align with the Banking Agencies' Incident Response Guidance. After considering the comments, we continue to believe the notification standard we proposed (and are adopting in the final amendments) is necessary to enable affected individuals to make their own determinations on needed self-protections regarding the incident.[91]

Regarding commenters' concerns about harmonizing Regulation S-P with state law requirements, state law notification standards vary widely such that broad harmonization would be impracticable, and a benefit of the final amendments is that they provide a consistent minimum federal notification standard to protect affected individuals in an environment of enhanced risk. This will, for example, provide additional protections for customers in states whose laws do not mandate notification without an affirmative determination of harm or provide

---

[90] *See* Proposing Release at nn.97-98 and accompanying text.

[91] *See* Proposing Release at n.100 (discussing reasons for divergence from Banking Agencies' Incident Response Guidance); *see also infra* sections II.A.3.b, II.A.3.e, II.A.4, II.B.2, and IV.C (also discussing the Banking Agencies' Incident Response Guidance).

an outside time by which notification must be provided.[92] This standard will protect all customers, regardless of their state of residence and reduce the potential confusion that could result from customers in one state receiving notice of an incident while customers in another state do not. Moreover, to the extent a covered institution will have a notification obligation under both the final amendments and a similar state law, a covered institution may be able to provide one notice to satisfy notification obligations under both the final amendments and the state law, provided that the notice includes all information required under both the final amendments and the state law, which may reduce the number of notices an individual receives.[93]

Relatedly, some commenters suggested eliminating or narrowing the concept of "affected individuals" entitled to notification in situations where a covered institution is unable to identify which specific individuals' sensitive customer information has been accessed or used without authorization. Instead of the proposed requirement that the covered institution must provide notice to all individuals whose sensitive customer information resides in the customer information system that was, or was reasonably likely to have been, accessed or used without authorization, commenters urged narrowing notification to individuals whose sensitive customer information was, or was reasonably likely to have been, accessed or used without authorization based on the covered institution's reasonable investigation.[94] These commenters stated that, by

---

92 *See* Proposing Release at nn.107-108 and accompanying text (discussing variation in state laws); *see also infra* section IV.C.2 for a fuller discussion of state law variations, and *infra* section IV.D.1.b(2) discussing timing of state law notification regimes.

93 *See also infra* section IV.C.2.a(2) (discussing states that excuse covered entities from individual notification under state law if the entities comply with the notification requirements of another regulator).

94 *See, e.g.,* IAA Comment Letter 1 (suggesting the rule's affected individuals' provision be modified to remove the reference to situations where an institution is unable to identify which specific individual's sensitive customer information has been accessed or used without authorization, as well as the presumption that affected individuals include individuals whose sensitive customer information resides in the breached customer information system); CAI Comment Letter (suggesting the provision be revised to remove the requirement to notify all individuals whose information is on an affected system, and instead require the institution to notify individuals whose information it reasonably believes was, or reasonably could have

requiring a covered institution to provide all affected individuals notice prior to the conclusion of an investigation and particularized determination, the proposed notification standard could result in the over-notification of individuals whose sensitive customer information may not have been accessed but was residing on a system that was compromised.[95] For example, one commenter posited a situation where a threat actor was able to compromise an employee's email account through a phishing email, and access documents accessible through that account's shared file server. According to this commenter, if the covered institution were unable to determine which files containing personal information actually were accessed, the institution would be required to provide notice in connection with millions of records, even though the "vast majority of files and data on that file server would not have been accessible to the employee or to the threat actor."[96] These commenters stated that the resulting over-notification could, in turn, desensitize or unnecessarily disturb individuals whose information was not actually compromised, and might increase costs and litigation and reputational risks for the covered institution, its service providers, or other financial institutions whose contracts reside on the system.[97]

For similar reasons to those discussed above,[98] we were not persuaded by commenter suggestions to narrow the scope of affected individuals entitled to notification in cases where a breach has or is reasonably likely to have occurred, but the covered institution is unable to identify which specific individuals' sensitive customer information has been accessed or used without authorization.[99] Because of the potential that customers might be adversely affected by

---

been, subject to unauthorized access based on the finding of its investigation).

95 *See, e.g.*, CAI Comment Letter; Computershare Comment Letter; IAA Comment Letter 1.

96 CAI Comment Letter.

97 *See also infra* section IV.D.1.b.(4) (discussing reputational costs).

98 *See supra* footnotes 90-93 and accompanying text.

99 *See supra* footnotes 94-97 and accompanying text.

the breach, covered institutions should be required to provide notice to affected individuals in these circumstances so they may make their own determination as to whether to take remedial actions.

Contrary to the concerns expressed by some commenters, under the proposed and final amendments, a covered institution would not need to provide notice in connection with files or data residing on a system where it knows that information was not used or accessed.[100] Rather, a covered institution is only required to provide notification to an affected individual where her sensitive customer information was, or is reasonably likely to have been, accessed or used without authorization.[101] Additionally, a covered institution need not provide notice where, after a reasonable investigation of the facts and circumstances of the incident, it has determined that sensitive customer information has not been, and is not reasonably likely to be, used in a manner that would result in substantial harm or inconvenience. To address these commenters' concerns, in a change from the proposal, the final amendments explicitly provide that, in cases where a covered institution reasonably determines that a specific individual's sensitive customer information that resides in the customer information system was not accessed or used without authorization, the covered institution need not provide notice to that individual.[102] Thus, a covered institution would not have an obligation to provide notice to an affected individual whose files happened to reside on a breached information system if it was able to reasonably conclude that those files were not subject to unauthorized use or access.

The notification standard should help to improve security outcomes by incentivizing covered institutions to conduct more thorough investigations after an incident occurs because the

---

100 *See supra* footnote 96 and accompanying text.

101 *See* final rule 248.30(a)(4)(i).

102 *See* final rule 248.30(a)(4)(ii).

rule does not permit a covered institution to rebut the presumption of notification without conducting a reasonable investigation. Further, the rule's requirement that a covered institution provide notice to all affected individuals where it is unable to identify which specific individuals' sensitive customer information has been accessed or used without authorization should incentivize covered institutions to establish procedures (for themselves and their service providers) that provide robust protections for sensitive customer information. For example, it may encourage covered institutions to employ a principle of least privilege, so that users' access rights to sensitive customer information on a particular information system are limited to the information strictly required to do their jobs.[103] Protections that limit the scope of any breaches reduce the investigation and notification costs (and as a consequence, the potential harm) resulting from a breach.

For a covered institution's customer notification procedures to remain reasonably designed to notify each affected individual whose sensitive customer information was reasonably likely to have been compromised, as required by the final amendments, the covered institution's policies and procedures generally should be designed to include revisiting notification determinations whenever the covered institution becomes aware of new facts that are potentially relevant to the determination.[104] For example, if at the time of the incident, a covered institution determines that risk of use in a manner that would result in substantial harm or inconvenience is

---

[103] *See, e.g.*, *Defend Privileges and Accounts,* National Security Agency Cybersecurity Information ("Least privilege is the restriction of privileges to only those accounts that require them to perform their duties, while limiting accounts to only those privileges that are truly necessary. Doing this reduces the exposure of those privileges to a smaller, more easily manageable set of accounts. Local administrative accounts and accounts for software program management and installation are particularly powerful, but have small scopes of control and should be restricted as much as possible") (available at https://media.defense.gov/2019/Sep/09/2002180330/-1/-1/0/Defend%20Privileges%20and%20Accounts%20-%20Copy.pdf).

[104] *See* final rule 248.30(a)(3).

not reasonably likely based on the use of encryption in accordance with industry standards, but subsequently the encryption is compromised or it is discovered that the decryption key was also obtained by the threat actor, the covered institution generally should revisit its determination.

As discussed in more detail below, the scope of the final amendments will apply to customer information in a covered institution's possession or that is handled or maintained on the covered institution's behalf, regardless of whether such information pertains to (a) individuals with whom the covered institution has a customer relationship or (b) to the customers of other financial institutions where such information has been provided to the covered institution.[105] Some commenters expressed concern that, as a result of this scope, covered institutions would be required to provide notification to customers of other institutions with whom they do not have a preexisting relationship.[106] One of these commenters suggested that it was unclear how a third-party service provider's notice to a covered institution of a breach would affect that covered institution's obligations.[107] Additionally, some commenters addressed circumstances where multiple covered institutions would all be required to notify affected individuals concerning the same incident, asserting that requiring all covered institutions involved to provide notices to customers would be burdensome, duplicative, and confusing to customers.[108]

Where a covered institution experiences an incident involving sensitive customer information related to the customers of another covered institution, commenters generally suggested that the covered institution that has the customer relationship with the customer whose

---

105 *See infra* section II.B.1.

106 *See* ACLI Comment Letter; Federated Hermes Comment Letter; ICI Comment Letter; SIFMA Comment Letter 2.

107 *See* ACLI Comment Letter.

108 *See* CAI Comment Letter; Computershare Comment Letter.

information was affected should be responsible for providing the required notice.[109] These commenters asserted that this would be more efficient because, if the covered institution that experienced the incident did not have a customer relationship with an affected individual, that covered institution might not have contact information for the individual necessary to send a notice.

After considering comments, we are modifying the proposal to avoid requiring multiple covered institutions to notify the same affected individuals about a given incident. In an effort to minimize duplicative notices, rather than requiring the covered institution with the customer relationship to send the notice as some commenters suggested, the final amendments only require a covered institution to provide notice where unauthorized access to or use of sensitive customer information has occurred at the covered institution or one of its service providers that is not itself a covered institution.[110] That covered institution will have information about the incident itself that is necessary to properly inform affected individuals. Thus, in response to the commenter question about the relationship between a covered institution's receipt of a breach notification from a third party service provider and the covered institution's own obligations,[111] where a service provider (that is not itself a covered institution) provides notice to a covered institution that a breach in security has occurred resulting in unauthorized access to a customer information system maintained by the service provider,[112] that covered institution will be required to initiate

---

109 *See* SIFMA Comment Letter 2; ACLI Comment Letter; Federated Hermes Comment Letter; CAI Comment Letter. Two of these commenters suggested that the covered institution with the customer relationship may make arrangements with other institutions to provide the notice on its behalf. SIFMA Comment Letter 2; ACLI Comment Letter.

110 Final rule 248.30(a)(4). If a covered institution is acting as a service provider, in addition to its own obligations under rule 248.30, it must provide notification to the other covered institution as required by the policies and procedures required in rule 248.30(a)(5)(i).

111 *See* ACLI Comment Letter.

112 *See* final rule 248.30(a)(5)(i)(B).

its incident response program under the final amendments[113] and thereafter, if applicable, provide notice to affected individuals.[114] While we appreciate, as offered by commenters,[115] that a covered institution may not have access to the contact information for some customers, it can coordinate with the covered institution that has a customer relationship to receive contact information as needed for the notices.[116]

Moreover, in another modification from the proposal, the final amendments also provide that a covered institution that is required to notify affected individuals may satisfy that obligation by ensuring that the notice is provided.[117] Accordingly, if a covered institution experiences an incident affecting another covered institution's customers, although the covered institution that experienced the incident is responsible for notification under the final amendments, the two covered institutions can coordinate with each other as to which institution will send the notice.

b. Definition of "Sensitive Customer Information"

As discussed above, covered institutions will be required to notify customers when "sensitive customer information" was, or is reasonably likely to have been, accessed or used without authorization, subject to a reasonable investigation. As proposed and as adopted, the final amendments define the term "sensitive customer information" to mean "any component of customer information alone or in conjunction with any other information, the compromise of

---

113 *See id.*; *see also infra* Section II.A.4.a.

114 *See* final rule 248.30(a)(4)(iii). As described above, a covered institution need not provide notice where, after a reasonable investigation of the facts and circumstances of the incident, it has determined that sensitive customer information has not been, and is not reasonably likely to be, used in a manner that would result in substantial harm or inconvenience. *See* final rule 248.30(a)(4)(i).

115 *See* ACLI Comment Letter, SIFMA Comment Letter 2.

116 Further, as discussed below, a covered institution will be permitted to enter into a written agreement with its service provider to notify affected individuals on its behalf in accordance with the notice requirements. *See* final rule 248.30(a)(5)(ii); *see also supra* section II.A.4.

117 Final rule 248.30(a)(4) (requiring covered institutions to either provide notice or ensure that such notice is provided).

which could create a reasonably likely risk of substantial harm or inconvenience to an individual identified with the information."[118] This definition is calibrated to include types of information that, if exposed, could put affected individuals at a higher risk of suffering substantial harm or inconvenience through, for example, fraud or identity theft enabled by the unauthorized access to or use of the information.[119] As with the proposal, the final amendments provide examples of the types of information that will be considered sensitive customer information.[120] These examples include certain customer information identified with an individual that, without any other identifying information, could create a substantial risk of harm or inconvenience to an individual identified with the information,[121] along with examples of combinations of identifying information and authenticating information that could create such a risk to an individual identified with the information.[122]

One commenter supported our proposed definition of sensitive customer information and emphasized the benefits of a broad definition.[123] According to this commenter, this breadth helps protect customers by ensuring that they can take the necessary steps to minimize their exposure

---

118 *See* final rule 248.30(d)(9)(i). The definition is limited to information identified with customers of financial institutions. *See* final rule 248.30(d)(5)(i); *infra* section II.B.1. As proposed, information pertaining to a covered institution's customers and to customers of other financial institutions that the other institutions have provided to the covered institution are subject to the safeguards rule under the final amendments, including the incident response program and customer notice requirements. *See* final rule 248.30(a); *infra* section II.B.1.

119 *See supra* section II.A.3.a.

120 *See* final rule 248.30(d)(9)(ii).

121 These examples include Social Security numbers and other types of identifying information that can be used alone to authenticate an individual's identity such as a driver's license or identification number, alien registration number, government passport number, employer or taxpayer identification number, biometric records, a unique electronic identification number, address, or routing code, or telecommunication identifying information or access device.

122 These examples include information identifying a customer, such as a name or online user name, in combination with authenticating information such as a partial Social Security number, access code, or mother's maiden name.

123 *See* Better Markets Comment Letter.